

TÀI LIỆU YÊU CẦU KỸ THUẬT HỆ THỐNG

Nền tảng Sàn Giao dịch Thương mại Điện tử Thuê xe Tự lái - vnigo.sbs

Áp dụng cho:	Đội ngũ Kỹ thuật (Tech Team / Developers)	Phiên bản:	1.0 (Bản rã nhánh Module)
Mục tiêu:	Chia nhỏ mảng tính năng để lập trình code, tránh lỗi hệ thống khi triển khai diện rộng.	Ngày khởi tạo:	13/07/2026

Lưu ý chung cho Đội ngũ Tech: Tài liệu này được biên soạn nhằm bóc tách cấu trúc hệ thống thành các phần độc lập. Đội ngũ cần ưu tiên hoàn thiện và nghiệm thu triệt để Giai đoạn 1 trước khi cấu hình tích hợp các module thương mại hóa ở Giai đoạn 2.

PHẦN I: GIAI ĐOẠN 1 - PHÁT TRIỂN HẠ TẦNG CỐT LÕI & PHÁP LÝ AN TOÀN

MODULE 1: Xác thực Người dùng & Bảo mật Dữ liệu cá nhân

GIAI ĐOẠN 1 - ƯU TIÊN CAO NHẤT

1.1 Luồng Đăng ký & Phân cấp Tài khoản

- Khách thuê xe:** Đăng ký tối giản bằng Số điện thoại. Xác thực bắt buộc qua mã **SMS OTP**. Hồ sơ cơ bản bao gồm Họ tên và Email.
- Chủ xe (Bên cung cấp dịch vụ):** Bắt buộc hoàn thiện thông tin định danh pháp lý trước khi được quyền đăng tải bài viết đầu tiên (Tuân thủ Nghị định TMĐT). Dữ liệu yêu cầu gồm: Họ và tên, Số điện thoại xác thực, Số CCCD, và Mã số thuế cá nhân (nếu có).

1.2 Kỹ thuật xử lý Tài liệu Nhạy cảm (CCCD & Giấy phép lái xe)

Để tuân thủ Nghị định 13/2023/NĐ-CP về Bảo vệ dữ liệu cá nhân, đội ngũ thiết kế luồng xử lý file ảnh upload như sau:

Yêu cầu Xử lý Ảnh (Bắt buộc):

Khi người dùng (Chủ xe/Khách) upload ảnh CCCD hoặc GPLX, hệ thống backend phải tự động đóng dấu bản quyền hình ảnh (Watermark) dưới dạng text chìm xuyên góc 45 độ trước khi lưu vào database. Chuỗi

ký tự đóng dấu: "Bản sao chỉ dùng cho mục đích xác thực tại vnigo.sbs - Ngày [DD/MM/YYYY]" .

1.3 Kiến trúc lưu trữ và Phân quyền nội bộ (RBAC)

- Lưu trữ tập tin:** Tuyệt đối không lưu ảnh CCCD trong thư mục public của server web. Toàn bộ tập phải đưa vào Private Bucket (ví dụ: Amazon S3 Private Bucket) và chỉ được truy xuất qua liên kết có thời hạn (Presigned URL) do Backend sinh ra cho phiên làm việc của admin hợp lệ.
- Cơ chế Ghi nhật ký hệ thống (Admin Logs):** Xây dựng bảng lưu vết thao tác tối mật. Hệ thống tự động ghi nhận lại bất cứ khi nào có tài khoản quản trị viên click xem hoặc phê duyệt hồ sơ người dùng.

Trường Dữ Liệu Logs	Kiểu Dữ Liệu	Mô Tả Chức Năng
log_id	BIGINT (Primary Key)	Định danh duy nhất của dòng log hệ thống.
admin_id	INT (Foreign Key)	ID của tài khoản nhân viên/quản trị viên thực hiện thao tác.
action_type	VARCHAR(50)	Hành động cụ thể (Ví dụ: VIEW_CCCD , APPROVE_PROFILE).
target_user_id	INT (Foreign Key)	ID của người dùng bị truy xuất dữ liệu cá nhân.
timestamp	DATETIME	Thời gian chính xác xảy ra thao tác (Hệ thống tự động ghi).

MODULE 2: Cơ chế Tiếp nhận Báo cáo & Quy trình Tranh chấp

GIAI ĐOẠN 1 - VẬN HÀNH AN TOÀN

2.1 Công cụ Sàng lọc và Giảm thiểu Rủi ro Chủ động

- Tính năng Báo cáo (Report Button):** Thiết lập nút báo cáo vi phạm tại tất cả giao diện bài viết chi tiết của xe. Tích hợp sẵn các lý do cấu hình trước: "Lừa đảo tiền cọc", "Xe không đúng mô tả thực tế", "Thông tin liên hệ sai lệch", "Giá ảo".
- Hệ thống Đánh giá công khai (Rating & Review):** Cho phép người thuê để lại chấm điểm sao (1-5 sao) và bình luận văn bản sau khi kết thúc lịch trình nhằm kích hoạt cơ chế tự đào thải cộng đồng.

2.2 Quy trình Kỹ thuật Xử lý Tranh chấp Dân sự (4 Bước)

- Tiếp nhận:** Người dùng tạo khiếu nại qua biểu mẫu (Form). Backend yêu cầu bắt buộc đính kèm bằng chứng (Ảnh chụp hiện trạng, biên lai chuyển khoản cọc, ảnh chụp tin nhắn).
- Cô lập tài khoản (Tạm khóa):** Admin hệ thống nhận cảnh báo, chuyển trạng thái bài đăng hoặc tài khoản bị tố cáo sang `PENDING_VERIFICATION`. Gửi email/SMS thông báo tự động yêu cầu bên bị tố cáo phản hồi giải trình trong vòng 24h - 48h.
- Hòa giải trung gian:** Cung cấp cổng thông tin kết nối an toàn (Hiển thị lại thông tin liên lạc được bảo mật để hai bên tự đàm phán).
- Kết xuất pháp lý:** Nếu hòa giải thất bại và có sự can thiệp của Cơ quan Công an, hệ thống phải có tính năng xuất bộ dữ liệu lịch sử giao dịch (Log IP đăng nhập, lịch sử sửa bài đăng, bản sao tài liệu định danh) sang định dạng tệp `JSON/PDF` để bàn giao theo văn bản yêu cầu.

MODULE 3: Kỹ thuật Bảo mật Hạ tầng & Chống tấn công

GIAI ĐOẠN 1 - PHÒNG VỆ HỆ THỐNG

3.1 Tường lửa lớp ngoài và Mã hóa

- Cloudflare WAF:** Định cấu hình Cloudflare làm Proxy đứng trước máy chủ gốc. Kích hoạt Web Application Firewall (WAF) để lọc mã độc, chặn tấn công SQL Injection, Cross-Site Scripting (XSS) và ngăn chặn rà quét lỗ hổng thư mục database. Chặn tấn công từ chối dịch vụ (DDoS).
- Mã hóa mật khẩu:** Tuyệt đối không sử dụng các hàm băm yếu (MD5, SHA1). Bắt buộc áp dụng thuật toán mã hóa một chiều mạnh như `bcrypt` hoặc `Argon2` với độ muối (salt) cấu hình tiêu chuẩn.

3.2 Cơ chế Chống phá hoại và Spam tài nguyên (Rate Limiting)

Đội dev cần cấu hình giới hạn tần suất gọi API (Rate Limit) ở tầng Web Server (Nginx/Apache) hoặc tầng Application để tránh cạn kiệt tài nguyên hệ thống và bùng nổ chi phí dịch vụ bên thứ ba:

Tên API Endpoint	Giới Hạn Tần Suất	Mục Đích Bảo Vệ
<code>/api/v1/auth/send-otp</code>	Tối đa 1 lần / phút / 1 số điện thoại	Chống spam phí tổng đài SMS OTP và treo cổng SMS.
<code>/api/v1/auth/login</code>	Tối đa 5 lần sai / 15 phút / 1 IP	Chống tấn công dò mật khẩu tự động (Brute Force).
<code>/api/v1/report/submit</code>	Tối đa 3 lần / phút / 1 tài khoản	Chống spam gửi báo cáo rác làm nghẽn hàng đợi Admin.

3.3 Tính năng "Quyền được lãng quên"

Thiết lập nút "Xóa tài khoản" tại giao diện quản lý trang cá nhân của người dùng. Khi kích hoạt, backend xử lý theo cơ chế trì hoãn: Chuyển trạng thái sang `INACTIVE_PENDING_DELETE`, ẩn toàn bộ thông tin công khai. Sau 60-90 ngày (thời gian dự phòng xử lý tranh chấp phát sinh muộn), một tiến trình chạy ngầm (Cron job) sẽ thực hiện xóa vĩnh viễn hoặc ẩn danh hóa triệt để dữ liệu nhạy cảm khỏi cơ sở dữ liệu chính.

PHẦN II: GIAI ĐOẠN 2 - THƯƠNG MẠI HÓA (TRIỂN KHAI KHI ĐẠT MỐC 2000 XE)

MODULE 4: Hệ thống Điểm Dịch vụ & Xuất Hóa đơn Tự động

GIAI ĐOẠN 2 - TẠO NGUỒN THU

4.1 Bản chất Kỹ thuật của "Đồng tiền Nội bộ"

Hệ thống ghi nhận đây là "**Điểm dịch vụ trả trước**" (**Credits / Points**), không lưu tên hoặc định nghĩa dưới dạng tiền ảo. Chủ xe nạp tiền thật (VNĐ) để đổi lấy số điểm tương ứng trong ví tài khoản hệ thống dùng để trừ dần cho các dịch vụ: *Đăng tin xe VIP, Đẩy tin lên top, Ghim bài viết*.

4.2 Quy trình Tích hợp Cổng Thanh toán và API Hóa đơn Điện tử

Để tự động hóa hoàn toàn và đảm bảo tính chính xác cho kế toán thuế, luồng xử lý nạp tiền và xuất hóa đơn được thiết lập như sơ đồ logic dưới đây:

```
[Chủ xe nạp tiền] -> [Chọn Cổng Thanh Toán: VNPAY / MoMo]
|
v
[IPN Webhook phản hồi kết quả Thanh toán thành công (Thành tiền: VNĐ)]
|
+---> [Hành động 1: Cộng Điểm dịch vụ vào ví Chủ xe trên Website]
|
+---> [Hành động 2: Gọi API Hệ thống Hóa đơn Điện tử (MISA / Viettel)]
|
v
[Tự động tạo Hóa đơn dịch vụ với thuế suất VAT 10%]
|
v
[Đẩy dữ liệu lên Tổng cục Thuế & Gửi bản sao hóa đơn vào Email Chủ xe]
```

4.3 Đồng bộ Dữ liệu Bộ Công Thương

Khi bật tính năng thương mại hóa này, đội ngũ kỹ thuật có trách nhiệm cập nhật lại hồ sơ kỹ thuật của website, bổ sung chức năng **Thanh toán trực tuyến** trên cổng dịch vụ công của Bộ Công Thương (online.gov.vn) để chuyển đổi từ nhãn "Đã thông báo" sang nhãn "Đã đăng ký" hợp pháp.